

DPDP implementation plan for the MSME DPR tool

Internal plan · September 2026 · Simple-language build guide for notice, consent, under-18, user rights, audit, and retention. Not a legal opinion and not a DPDP compliance certificate.

One-line answer. The app is not aligned with India’s Digital Personal Data Protection Act, 2023 today. We can build most of the *product* controls in four code stages, plus one short decision stage and one legal/ops stage. Audit logging is part of the plan (Stage 1 for login and consent; Stage 2 for the full trail). After Stages 1–3 the *code* can be as aligned as this product can get. We still must not say “we comply with DPDP” until Stage 4 (contracts, named officer, breach process) is done by people, not only by software.

Contents

1. What this paper is (and is not)
2. The situation today
3. If the user is under 18
4. Audit — yes, it is in the plan
5. What “aligned in code” means
6. Stage 0 — Four decisions (locked)
7. Stage 1 — Notice, consent, age 18, safer AI, first audit
8. Stage 2 — User rights, complaints, nominee, full audit
9. Stage 3 — Keep less data, keep it for less time
10. Stage 4 — Organisation work the code cannot finish
11. Order of work for the AI agent
12. What we may say after each stage
13. Problems we will still hit

1. What this paper is (and is not)

This is a **build plan** so the MSME DPR tool handles people’s data in the way the DPDP Act expects — as far as software can.

It is **not** a lawyer’s certificate. After we build every screen and log in this paper, we still need:

- the legal gazette name behind “MSME One Department” (Stage 0 already names the department for the product);
- written contracts with OpenAI, Cloudinary, and the database host;

- a named human who reads `privacy.grievance@msmeone.gov.in` (mock address until a real inbox exists);
- a written plan if data leaks.

Until those exist, nobody should tell users, banks, or government that “we are DPDP compliant.”

2. The situation today

This tool helps entrepreneurs make **Detailed Project Reports** (DPRs) for banks and government schemes. To do that it collects:

- name, email, phone, location, Udyam number;
- business answers, costs, loans, scheme extras;
- often **Aadhaar** / **PAN** / **bank passbook** / **UPI** scans.

That is personal data. Some of it is very sensitive (identity documents and money).

What the app already has: login, password hashing, roles (entrepreneur / officer / admin), basic security headers.

What it does not have:

- a privacy notice before or at collection;
- clear, itemised consent (including a way to say no to AI);
- a user button to download or delete their own data;
- an audit log (the README mentions audit; the code does not);
- a rule that keeps Aadhaar and bank files out of AI prompts.

Register collects name, email, phone, location and Udyam with no notice and no consent box. Quality scoring and “fill with AI” can send stored form data to OpenAI. Files can go to Clouinary. So we are **not** aligned with DPDP today. README lines about GDPR, end-to-end encryption, anonymisation, and audit logging are claims, not features.

3. If the user is under 18

Two different questions get mixed up:

1. Can a young person want to start a company? **Yes.**
2. Can they be the **applicant** on this bank/scheme DPR, and can this app hold their Aadhaar? **No — not in their own name.**

Why. Under DPDP, anyone under 18 is a child. They cannot give adult consent. A parent or guardian must consent. In this product, schemes such as PMEGP, MUDRA and PM SVANidhi need the borrower to be 18 or older. A minor generally cannot sign a normal bank loan.

Scheme Finder already has an age option “under 18” and those loan schemes fail the “age 18+” test. We keep that.

What we will do in the product

- **Do not** create an account where the applicant is under 18.
- Show a clear message: *This site makes bank and scheme DPRs. The person named as the entrepreneur must be 18 or older. Ask a parent or guardian to register and create the DPR in their name.*
- If someone types a promoter age under 18 inside the form, do not generate or save that person as the applicant. Same message.

We are **not** building a special “child planning DPR” in this plan. The honest path is: the **adult** is the user and the promoter. The young person can be described as family or a future partner, not the borrower.

4. Audit — yes, it is in the plan

DPDP does not say “install a huge monitoring product.” It expects we can **show who touched whose data, when, and why** — especially KYC files, downloads, deletes, and when an officer opens someone else’s DPR.

We will store an **append-only** list of events. Nobody edits old rows. Each row stores only:

- date and time;
- who did it (user id and role);
- what they did (for example `login` or `dpr_download`);
- what it was about (for example a DPR id) — **not** the Aadhaar number, **not** the full DPR text;
- optional IP address.

Keep these logs **longer than the DPR files** (for example 12–24 months). If we delete a user, we do **not** wipe the log. We may hide their display name and keep the id.

Stage 1 starts audit (login and consent). **Stage 2** completes it (DPR, KYC, AI, export, delete, admin views, and screens to read the log).

5. What “aligned in code” means

After Stages 1, 2 and 3, the **product** can:

- tell people what we collect and why;
- get consent and let them take it back;
- refuse child applicants;
- keep KYC out of AI prompts;

- let people take a copy of their data and delete their account;
- take a complaint;
- record a nominee;
- keep an audit trail.

That is **as aligned as this codebase can be**. It is still not a legal statement of compliance without Stage 4.

DPDP DUTY	CAN WE COVER IT IN CODE?	STAGE
Notice (what, why, who, rights)	Yes — privacy page in English and Telugu	1
Consent and withdraw	Yes — flags on the user	1–2
Under-18 / guardian	Yes — block as applicant; parent message	1
Optional AI; purpose limit	Yes — AI switch + strip KYC from models	1
See my data (access)	Yes — export	2
Correction	Yes — profile and DPR edit, and log it	2
Erasure	Yes — full delete cascade	2
Grievance	Partial — form and email; a human must reply	2
Nomination (if user dies or cannot act)	Yes — name and contact on file	2
Security	Partial — login exists; tighten secrets and KYC storage	1 + 3
Audit / who touched what	Yes — append-only event list	1 + 2
Storage limit	Yes — delete old drafts on a schedule	3
Processors (OpenAI, Cloudinary)	Code: tell the user and send less. Legal: contracts	1 code, 4 legal
Data sent abroad	Say so in the notice; not a magic toggle	1 + 4
Breach notice to the Board	Log + written playbook; humans send the notice	2 log, 4 ops

6. Stage 0 — Four decisions (locked September 2026)

NOT A SOFTWARE TASK · THESE FOUR LINES GO ON THE NOTICE

The notice must use the organisation’s real name. These four answers are now written down. Stage 1 uses them. Stage 4 still confirms the legal entity on paper (gazette / department order), not only this product name.

#	DECISION	WHAT WE WILL PUT ON THE NOTICE
1	Who is responsible (Data Fiduciary)	MSME One Department. Stage 4 should still match this to the legal name of the body that actually runs the portal (for example the Industries department or the agency named in the government order). Until then, the product text is “MSME One Department”.
2	Grievance email	privacy.grievance@msmeone.gov.in — mock inbox for now, so Stage 1–2 can ship. Replace with a real mailbox someone reads before we say the complaint path is live. A form still saves the complaint in the app so nothing is lost if mail is not yet real.
3	How long unused drafts live	12 months after last edit of that DPR draft. Then delete or strip personal fields, and log the purge. Warn the user by email a few days before (good practice; the 48-hour rule in the DPDP Rules is written for other classes of platforms, but we still warn).
4	AI rule	AI is optional . Aadhaar, PAN, and bank files never go into the model. If the user says no to AI, we say clearly: <i>Fill with AI, quality scoring that uses a model, and similar AI help will not work. You can still fill the DPR yourself, save, and download.</i> Account consent is separate. We do not block registration just because they refuse AI.

Does “12 months after last edit” match the law?

Yes as a **policy**. It is not a number the Act forces on this product, and the Act also does not give us a longer “maximum allowance” we should stretch to.

- **DPDP Act, section 8(7).** Keep personal data only while the stated purpose is still being served, or another law says we must keep it. When the user withdraws consent, or the purpose is over, we erase (and tell our processors to erase). There is no “keep for 12 months / 3 years / 10 years” line for a DPR tool.
- **The 3-year inactivity clock in the DPDP Rules (Third Schedule)** is only for huge e-commerce, social-media, and gaming platforms (crores of users). This MSME DPR tool is not in that list. That 3-year figure is **not** extra time the law “allows” us to take.
- **What the law actually allows.** We may keep a DPR while the purpose we wrote on the notice is true — for example while the person still uses the tool to finish or reuse that report. We may not keep it “just in case” after that purpose is over. So the ceiling is the purpose, not a gift of extra years.
- **Why 12 months after last edit is still okay.** It is a clear, conservative rule: if nobody has edited the draft for a year, we treat the drafting purpose as over. That is stricter than “keep forever while the account exists,” which would also be lawful if we said that purpose on the notice. We choose the shorter, cleaner clock.
- **Do not mix this with logs.** Processing logs (who logged in, who downloaded, who deleted) should be kept **at least 12 months** when the DPDP Rules on logs apply — that is a *minimum* for the trail, not a reason to keep Aadhaar scans. The plan already keeps audit rows longer than the draft files (12–24 months).
- **Do not auto-delete the whole account** only because one draft is old. Delete or strip that idle draft. If they still log in, the account stays. If they ask to delete the account, we erase (Stage 2).

- **Submitted / downloaded copies** used for a live bank or DIC file: say on the notice whether those follow the same 12-month last-edit rule or a longer “until the scheme file is closed” rule. Default in this plan: same 12-month last-edit rule unless Stage 4 writes a longer legal hold.

Bottom line on time. Twelve months after last edit is aligned with DPDP because it is a stated purpose window, not because the Act says “12 months.” The law does not give this product a longer official bonus period. We are not leaving data sitting because we think we “may as well take 3 years.”

7. Stage 1 — Notice, consent, age 18, safer AI, first audit

FIRST PRODUCT SLICE · STOP SILENT COLLECTION

Goal. From this moment we do not quietly collect data, we do not treat a child as the applicant, and we do not send KYC to OpenAI.

Done when: a new user sees the notice and ticks consent; old users are blocked until they accept; a 16-year-old cannot be the DPR applicant; KYC is not in AI calls; login and consent appear in the audit table.

7.1 Privacy notice page

Add a page such as /privacy in English and Telugu, in simple language:

- who we are (from Stage 0);
- what we collect (account, DPR answers, optional KYC files);
- why (make a DPR, match schemes, optional AI help);
- who else may see it (hosting, Cloudinary for files, OpenAI only if AI is on);
- how long we keep it;
- how to complain and how to delete.

Link this page from Register, and from Create New Latest DPR.

7.2 Consent stored on the user

Save on each user:

- **account** — needed to use the app (cannot skip);
- **aiAssist** — send form text (not KYC) to AI; can be off. Next to the box: if this is off, Fill with AI, model-based quality scoring, and other AI help will not run; the user can still type, save, and download the DPR;
- **analytics** — optional;
- which notice version they agreed to, and when.

Register cannot succeed without account consent and a working link to the notice.

7.3 People already in the database

Old users never saw a notice. On next login, show a **blocking popup** with the same notice and the same checkboxes. They cannot use the dashboard until they accept.

7.4 Under 18

- Ask age (or date of birth) at register.
- If under 18: do not create them as the entrepreneur. Show the guardian message.
- If promoter age in the DPR form is under 18: do not generate or save that person as the applicant. Same message.
- Scheme Finder: under 18 still fails loan schemes; add the guardian line.

7.5 Stop sending secrets to AI

One shared function used everywhere we call a model (suggestions, fill-all-steps, quality score, chat):

- remove Aadhaar, PAN, passbook, UPI, file URLs, ID numbers;
- if AI consent is off, those APIs refuse in plain language: AI features are off; the rest of the DPR tool still works.

7.6 Small security in the same stage

- Do not use a default JWT secret in production.
- Do not print full DPR HTML or personal data in server logs.

7.7 Audit in Stage 1

Create the append-only event list now. In this stage, record:

- register;
- login success, login failed, logout;
- consent given or withdrawn;
- notice accepted.

Not in Stage 1. Full “delete my account” screen, encrypting files on disk, or the admin audit browser. Those are Stage 2 and 3.

8. Stage 2 — User rights, complaints, nominee, full audit

Goal. A person can see, take, fix, and erase their data. We can show an officer the trail.

Done when: a test user can export, turn AI off, delete themselves (including files), and those actions appear in the admin audit list.

8.1 Privacy settings page

A page such as `/account/privacy`:

- **Download my data** — JSON or ZIP: profile (no password), projects, DPR answers. Log it as data export.
- **Turn AI off** — we keep their DPR; we stop model calls. Log the consent change.
- **Edit name, phone, email** — already exists; start logging the change.
- **Nominee** — name plus phone or email of someone who may act if they die or cannot act (DPDP nomination).
- **Delete my account** — strong confirm, then really delete.

8.2 Delete must be complete

One shared function. The user's button and the admin's delete both use it:

1. their projects;
2. their DPR versions;
3. files on Cloudinary and on disk;
4. any stored OpenAI file or thread ids;
5. then the user row.

Keep audit rows. Incomplete delete is worse than no delete. Test with a dummy DPR that has a real upload.

8.3 Full audit list (add to Stage 1)

WHAT WE LOG	WHY
Create, change, download, or delete a DPR	Main personal file
KYC upload or delete (file id only)	Aadhaar / PAN
AI call (which feature, not the prompt text)	Use of a processor
Data export	Right of access
Account delete	Erasure
Admin opened another user's DPR or profile	Highest risk
Admin deleted a user	Same

WHAT WE LOG	WHY
Privacy complaint submitted	Grievance path

Admin: search by user, action, date; download CSV for a complaint.

User: “Recent activity on my account” (logins, downloads, exports) — not other people’s data.

8.4 Grievance

A short form: “I have a privacy request.” It emails `privacy.grievance@msmeone.gov.in` (mock until a real inbox is live) and saves a row in the app so the request is not lost. Log it. A human must still reply. DPDP expects a reply path (the Rules speak of about 90 days for rights requests), not a chatbot that “closes” the Act.

9. Stage 3 — Keep less data, keep it for less time

THIRD PRODUCT SLICE · DO NOT HOLD AADHAAR AS AN OPEN LINK FOREVER

Goal. Scans are not public Mongo URLs; idle drafts do not live forever; logs still exist after a file is gone.

Done when: a test upload is not world-readable, and an old draft disappears on schedule (and the purge is logged).

9.1 Files

- Store KYC privately (not a public URL inside the database).
- In the DPR, show Uploaded or Pending, not the scan itself in JSON if we can avoid it.
- Optional: encrypt files at rest with a key in environment variables.
- Do not save the Aadhaar **number** as a field — only whether a document is present.

Banks and DIC may still want an attachment on a PDF. That is a product choice: status in the report versus keeping the scan. Write the choice into the notice.

9.2 Automatic clean-up

- Drafts not edited for 12 months → delete or strip personal fields. Email a warning first. Do not delete the whole account only because one draft is old.
- Log that purge.
- Submitted DPRs: keep as long as the notice says, then delete and log.

Audit logs stay after a draft is gone. No extra under-18 product in this stage.

10. Stage 4 — Organisation work the code cannot finish

LEGAL AND OPS · REQUIRED BEFORE ANYONE SAYS “WE COMPLY”

The agent may: list processors on the privacy page, use a grievance email from configuration, and **remove** README lines that claim GDPR, encryption, anonymisation, and audit until Stage 2 is actually live.

You or a lawyer must:

- contracts with OpenAI, Cloudinary, and the database host (purpose, no training on our users’ data, delete when we ask);
- confirm the legal name behind “MSME One Department” and replace the mock grievance inbox with a mailbox a person reads;
- write what you do if data leaks (tell the Board and the people affected).

Without Stage 4, Stages 1–3 are good product hygiene, not a compliance certificate.

11. Order of work for the AI agent

One slice at a time. Do not merge the AI strip without the notice and consent screens.

1. **1a** — User consent and age fields; privacy page; register and re-consent popup; under-18 plus guardian text; audit for login and consent.
2. **1b** — Strip KYC from every AI route; honour the AI switch; audit for AI calls.
3. **2** — Privacy settings: export, nominee, withdraw, delete cascade, complaint form; full audit plus admin log screen.
4. **3** — Private KYC, retention job, log purges.

12. What we may say after each stage

AFTER	WE MAY SAY	WE MUST NOT SAY
Stage 1	We tell people and ask before collecting. Children are not applicants. AI does not get KYC. Login and consent are logged.	We comply with DPDP.
Stage 2	Users can take and delete their data. We keep an audit trail they and an officer can use.	Vendors are contracted. Aadhaar is safe forever.
Stage 3	We do not keep open KYC forever. Old drafts are cleaned up.	Legal compliance is complete.
Stage 4	Counsel may talk about DPDP alignment.	The software agent cannot sign that.

13. Problems we will still hit

- Wrong organisation name on the notice.
- Delete that forgets Cloudinary or a local upload folder.
- Old users without the blocking popup.
- One AI caller still sending the full form if we miss it in Stage 1b.
- Banks still wanting KYC attached to a PDF — Stage 3 must match what DIC actually files.

Start here. Stage 0 is locked (MSME One Department, mock grievance mail, 12-month last-edit drafts, optional AI with a clear “AI will not work” warning). Next is Stage 1a: notice, consent, under-18, login/consent audit. Do not skip 1a to “just add audit” or “just add delete.”